JS

Jahangir Shukurov | GRC Portfolio

ISO/IEC 27001:2022 Gap Assessment

Executive briefing for the Management Board of Orvanta Payments UAB

27 November 2026 | Confidential (sample)

Sample engagement — fictional company, prepared for portfolio purposes.

Certification by November 2027 is achievable if we start in December

1.4/5

average maturity

Target is 3 on every item

16%

already at target

20 of 123 requirements

38

P1 gaps

Start within 90 days

EUR 2.4M

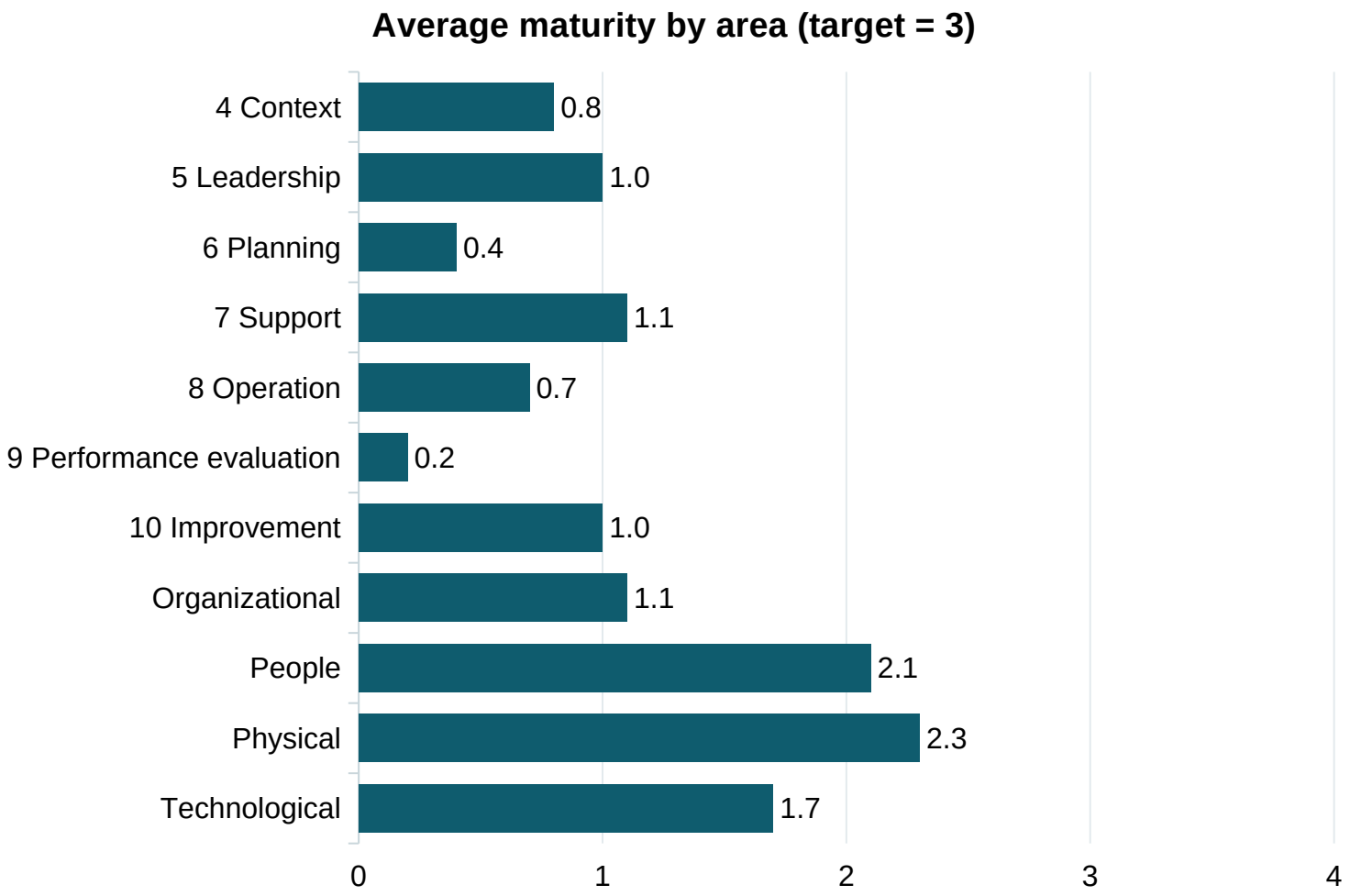
annual revenue at stake

About 11% of FY2025 net revenue

What this means

Encryption, redundancy and infrastructure as code are real strengths. The gaps sit in governance, identity, detection and recovery. They are fixable within 12 months, with clear sponsorship, funding and engineering time.

Governance lags technology, and no clause area is near target



Weakest

Performance evaluation at 0.2: no audit, review or measurement yet

Strongest

Physical at 2.3: production runs in AWS and offices are simple

Why it matters

Certification tests the management system, not only the technology

Five gaps carry the highest priority scores

1	**Attacks would go undetected**	An intruder could stay for weeks because no one is watching.	Nino Beridze Jun 2027
2	**No working risk management**	Spending follows the last customer question, not the biggest risk.	Lukas Jankauskas Mar 2027
3	**Suppliers are unassessed**	Critical services run through suppliers nobody has assessed.	Eglė Norvilaitė Jun 2027
4	**No assurance cycle**	No audit or management review means Stage 2 cannot pass.	Eglė Norvilaitė Aug 2027
5	**Recovery is unproven**	If backups fail, ledgers and customer funds records are at risk.	Rashad Guliyev May 2027

One realistic attack path runs through six open gaps

1 Phish an engineer

T1566 Phishing

An engineer on an unmanaged laptop enters a password on a fake login page.

2 Harvest stored keys

T1552.001 Credentials In Files

Long-lived AWS keys in nine repositories work without MFA.

3 Become an administrator

T1078.004 Cloud Accounts

A shared admin account gives full rights with no named user in the logs.

4 Stay unnoticed

No technique needed

Logging is off in one AWS account and nobody reviews the rest.

5 Take customer data

T1530 Data from Cloud Storage

KYC files and databases are broadly readable, and bulk downloads raise no alert.

6 Destroy the backups

T1490 Inhibit System Recovery

Backups share the production account and no restore has ever been tested.

Breaking any one step stops the path. Quick wins start closing steps 3, 4 and 6 within 30 days.

Eight quick wins cut real risk within 30 days

3d — **Enable CloudTrail in the legacy account**
Rashad Guliyev

7d — **Purge card numbers from tickets, add redaction**
Mantas Žukas

14d — **Enforce MFA on Kyrovia and agent Zendesk**
Farid Ismayilov

7d — **Cut Okta super admins to two plus break-glass**
Farid Ismayilov

14d — **Protect all production repositories**
Tural Mammadli

14d — **Remove leaver access within 24 hours**
Justina Mockutė

21d — **Run and record one full database restore**
Rashad Guliyev

7d — **Publish incident call list and report channel**
Nino Beridze

A four-phase plan reaches the certificate decision by 30 November 2027

Foundation

Dec 26 to Mar 27

- Program and budget
- Scope and policy
- Risk assessment
- Statement of Applicability

Build

Jan to Jun 27

- Policies and procedures
- Identity and laptops
- Change control
- Backups, BIA, suppliers

Operate

Feb to Nov 27

- SIEM and daily triage
- Incident playbooks
- KPI dashboard
- Awareness program

Certify

Jul to Nov 27

- Internal audit: Jul
- Management review: Aug
- Stage 1: Sep
- Stage 2: Oct

Five decisions are needed from this Board

1	**Sponsor the ISMS program as a board-level priority**	Ugnė Baltrūnaitė	**30 Nov 2026**
2	**Fund the roadmap, with a third security hire and a SIEM**	Ugnė Baltrūnaitė	**15 Dec 2026**
3	**Move the CISO reporting line from the CTO to the CEO**	Ugnė Baltrūnaitė	**31 Dec 2026**
4	**Include the Baku subsidiary in the ISMS scope**	Tural Mammadli	**15 Jan 2027**
5	**Commission a QSA review of PCI DSS scope and level**	Nino Beridze	**31 Jan 2027**